THE SMALL BUSINESS GUIDE

# THE BREACH CAME THROUGH YOUR SUPPLIER



Third-Party Data and
**Cybersecurity Risks**

VENDOR CHECKS | CONTRACTS | GDPR | INCIDENT RESPONSE

ZIRLANDIA MILKOVIC

THIRD-PARTY DATA AND CYBERSECURITY RISKS

# THE BREACH CAME THROUGH YOUR SUPPLIER

The Small Business Guide to Third-Party Data and Cybersecurity Risks

ZIRLANDIA MILKOVIC

**The Breach Came Through Your Supplier**
The Small Business Guide to Third-Party Data and Cybersecurity Risks

© 2026 Zirlandia Milkovic. All rights reserved. No part of this book may be reproduced without written permission, except for brief quotations in reviews.

First edition, 2026. Research cut-off: 9 November 2026. British English. Companion resource: GDPRGard.eu.

This book is practical guidance, not legal, security or data-protection advice. All examples, businesses and people in worked scenarios are fictional.

# Contents

**START HERE**

Educational Disclaimer ..... 4
Introduction: The Call Came From Your Customer ..... 4
Who This Book Is For ..... 5
How to Use This Book ..... 6
The One-Page Supplier Check ..... 7

**CHAPTERS**

1. The Back Door You Built Yourself ..... 8
2. Who Your Suppliers Really Are ..... 11
3. How It Has Already Happened ..... 15
4. What Your Suppliers Can Touch ..... 18
5. Tier Your Suppliers ..... 22
6. Vendor Security Assessments Without a Security Team ..... 25
7. Reading the Evidence ..... 29
8. Contractual Responsibilities: What Must Be in Writing ..... 32
9. Who Pays? Liability, Insurance and the Limits of Contracts ..... 36
10. Keeping Watch After You Sign ..... 40
11. When the Breach Comes Through Your Supplier ..... 43
12. Telling Customers, Regulators and the Supplier ..... 47
13. Your 30-Day Plan ..... 50
14. Five Case Files ..... 53

**CLOSING**

Conclusion: Close the Back Door ..... 55

**APPENDICES**

Appendix A: Supplier Register ..... 56
Appendix B: Supplier Assessment Form ..... 57
Appendix C: Contract Clause Checklist ..... 59
Appendix D: Supplier Security Questionnaire ..... 61
Appendix E: Supplier Breach Response Log ..... 63
Appendix F: One-Page Supplier Policy Template ..... 65
Appendix G: Notification Worksheet ..... 67
Appendix H: Quarterly Review Log ..... 69

**BACK MATTER**

Glossary ..... 70
A Note on GDPRGard.eu ..... 71
About the Author ..... 71
Notes and Sources ..... 72

# Educational Disclaimer

This book is practical, educational guidance for owners and managers of small businesses. It is not legal, security, insurance or data-protection advice, and it does not create a professional relationship between the author and the reader.

Data-protection law, contract law and supplier practice differ between countries and change over time. Check the current position with a qualified lawyer, your insurer or your data-protection authority before relying on anything here for a decision that matters, especially one that involves customer data, a regulator or a dispute with a supplier.

Following the steps in this book may reduce your risk. It cannot guarantee that a supplier is safe, that a breach will not happen, or that you will meet every legal duty. Checklists, questionnaires, clauses and templates are starting points to adapt with professional advice, not finished legal documents. Nothing here is an instruction to test, probe or attack anyone else's systems; the techniques described are explained so that you can recognise and defend against them.

Every business, person and product in a worked example is **fictional** and labelled as such. Where the book describes a real incident, it is sourced in the notes at the back, and figures are given as reported by regulators, researchers or the press, which do not always agree.

# Introduction: The Call Came From Your Customer

Picture a Tuesday morning. A customer emails you, politely and a little suspicious. She has just received a phishing message that quotes, correctly, the name of the product she bought from you last spring and the last four digits of her phone number. Nobody outside your business should know both.

You check your systems. Nothing is missing. Your passwords are strong, your laptops are updated, and your own security is better than it was a year ago. You did everything you were told to do.

Two days later you find the cause. Your online booking tool, a supplier you chose in an afternoon four years ago, was breached. It held a copy of your customer list. Its owners knew for three weeks and told no one, because the contract you clicked through never said they had to.

The customer does not care whose server it was. She gave her details to **you**. The regulator will ask what **you** did to choose, instruct and check that supplier. Her lawyer, if it comes to that, will write to **you** first.

This is the shape of the modern small-business breach. It is not usually a hacker defeating a locked front door. It is a door you never knew was open, belonging to a company you pay, holding data you handed over, under terms you never read. Large studies of breaches now find the involvement of a third party roughly doubling in a year, and some of the most damaging incidents of the past decade began with a supplier rather than with the victim itself [1].

The unfair part is that you cannot hand the responsibility over along with the data. Under the GDPR and similar laws, a business that decides why and how personal data is used stays accountable for it when someone else holds it on its behalf. The fair part is that this is manageable. You do not need a security team. You need to know who your suppliers are, what they can touch, what they promised in writing, and what you will do on the day they call.

This book walks through exactly that: four questions, in the order you will meet them.

> **The rule.** You can outsource the work. You cannot outsource the accountability. Every supplier that touches your customers' information is part of your security, whether or not you chose to think of them that way.

## Who This Book Is For

**Owners and managers of small and growing businesses.** You use a dozen or more services to run the company: accounting, email, payments, booking, marketing, hosting, support. Each of them holds a piece of your customers' trust.

**Freelancers, consultants and agencies.** You are a supplier to your clients and a customer of your own tools. Your clients will increasingly send you the questionnaires this book teaches you to send.

**Online shops, SaaS founders and service firms.** Your product is built on other people's platforms, and your customers assume you vouch for all of them.

**Anyone handling compliance, IT or privacy part-time.** You will find a ready-made register, assessment form, clause checklist, questionnaire, response log and policy that you can adopt as they stand.

You do **not** need to be technical or legal. Where a technical or legal idea matters, it is explained in everyday language, and where a clause or a form appears it is short, fictional and annotated.

# How to Use This Book

You can read it straight through in an evening, or dip in when you need it.

- **In a hurry?** Fill in the **One-Page Supplier Check** that follows, then read Chapters 4, 6 and 8. They cover the access, the assessment and the contract: the three things that matter most.
- **A supplier has just told you about a breach?** Go straight to Chapter 11, and keep Appendix E open beside it.
- **Signing a new supplier this week?** Read Chapters 5 to 8, then use Appendices B, C and D.
- **Need to put rules in place for a team?** Read Chapters 10 and 13, then adopt the policy in Appendix F.

Look for these markers:

- **The rule** boxes are the one idea to remember from a section.
- Checklists use boxes (☐). Print them or copy them into your own system.

- Numbers in square brackets, like [1], point to the Notes and Sources at the back.

The appendices are working documents. Write in them, copy them, and keep the completed versions: a dated record is most of what it means to say you took reasonable care.

## The One-Page Supplier Check

Answer these honestly before you read further. Each "no" or "don't know" is a chapter waiting for you.

- ☐ I can list every supplier that holds or can reach my customers' personal data. *(Chapters 2 and 4, Appendix A)*
- ☐ For each one I know exactly what data it holds and what it can access. *(Chapter 4)*
- ☐ My suppliers are ranked by how much damage they could do, and the top ones get more attention. *(Chapter 5)*
- ☐ Before I sign with a supplier I ask for evidence of its security, not just a promise. *(Chapters 6 and 7)*
- ☐ Every supplier that processes personal data for me has a signed data processing agreement. *(Chapter 8)*
- ☐ My contracts say how fast a supplier must tell me about a breach. *(Chapters 8 and 11)*
- ☐ I know which sub-suppliers my suppliers use, and I would be told if they changed. *(Chapter 8)*
- ☐ I review my important suppliers at least once a year and when something changes. *(Chapter 10)*
- ☐ When a contract ends, I can show that the supplier deleted or returned my data. *(Chapter 10)*
- ☐ I know exactly what I would do in the first hour if a supplier told me it had been breached. *(Chapter 11)*

**Scoring.** Ten ticks: you are ahead of most. Seven to nine: a good base with gaps. Four to six: you are exposed, but a few weeks of work fixes most of it. Three or fewer: the back door is open right now. That is fine; this is why you are here.

CHAPTER 1

# The Back Door You Built Yourself




Most small businesses picture a cyberattack as a siege. Someone, somewhere, hammers on the walls until a wall gives way. So they strengthen the walls: better passwords, antivirus, a firewall, a two-step login.

That work is worthwhile. But attackers are practical, and they go where the effort is lowest. If your walls are sound and your supplier's are not, the supplier is the shorter path.

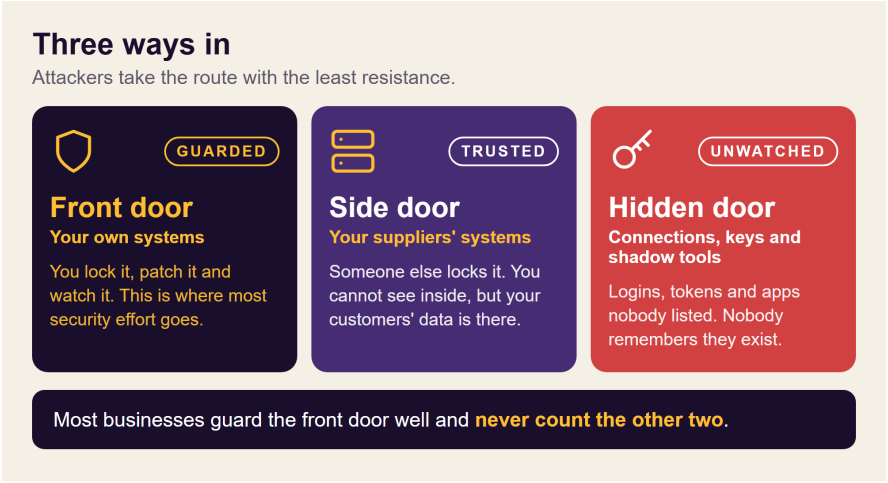
## Why suppliers are the easy way in

Three things make a supplier more attractive to an attacker than you are.

**Concentration.** One supplier serves many customers. Breaking into a payroll provider, a booking platform or an email-marketing service can yield the data of thousands of businesses in one operation. For the attacker, it is the difference between robbing one house and the whole street.

**Trust.** Your systems are set up to accept your suppliers. Their staff have logins, their software has permission to connect, their emails get through your filters. An attacker who borrows a supplier's identity inherits that trust.

**Invisibility.** You cannot see inside a supplier. You do not know whether its staff use multi-factor login, whether its backups work, or whether the one person who runs its servers has just left. You find out when something goes wrong.




The back door: three routes in, and the one most businesses forget to guard

## What the numbers say

Annual breach studies keep telling the same story. The widely cited Verizon Data Breach Investigations Report for 2025 found that third-party involvement in breaches had risen to about 30 per cent, roughly double the share a year earlier [1]. Figures differ by study and method, and no single number should be treated as exact. The direction is what matters: more of the damage is arriving through partners, platforms and service providers.

The pattern is also visible in the cases that make the news. A heating contractor's login led to one of the biggest retail card breaches in history. A single trusted software update reached thousands of organisations. A file-transfer product used by banks, schools and councils was emptied in a matter of days. Chapter 3 tells these stories in plain terms. Each time, the victim businesses were doing their own jobs adequately. What they lacked was a clear view of the supplier that sat behind them.

## Your three exposures

When a supplier fails, you can be hurt in three different ways, and it helps to name them.

1. **Your data is stolen.** The supplier held customer, employee or financial information on your behalf and lost it.

2. **Your systems are reached.** The supplier had a connection into your network, your accounts or your cloud, and the attacker used it.
3. **Your service stops.** The supplier goes offline, is locked by ransomware, or ships a faulty update, and you cannot trade.

Most of this book is about the first two, because they trigger legal duties as well as practical ones. The third matters too, and the same supplier discipline helps with it.

## What "responsible" really means

Business owners often say, with some relief, "it was the supplier's fault". Sometimes it was. But responsibility is not a single object that sits on one side or the other.

- The **supplier** is responsible for its own security and for following your instructions about the data.
- **You** are responsible for choosing the supplier with care, giving lawful instructions, putting the right terms in writing, limiting what you hand over, and acting quickly when something goes wrong.
- **Your customers** are entitled to hold you to account, because you are the one they dealt with.

If a regulator asks what happened, "they were a big, well-known company" is not an answer. "Here is how we assessed them, here is what we signed, here is what we checked each year, and here is how fast we acted" is.

> **The rule.** A supplier's failure becomes your failure the moment you cannot show how you chose, instructed and checked it.

## What this book will not ask of you

It will not ask you to audit anyone's data centre, to read a hundred-page security report line by line, or to hire a consultant. It asks for a short register, a ten-minute assessment, a handful of clauses, and a calm plan. Done properly, that takes a few hours spread over a month, and it changes your position from "we hoped for the best" to "we can show our work".

CHAPTER 2

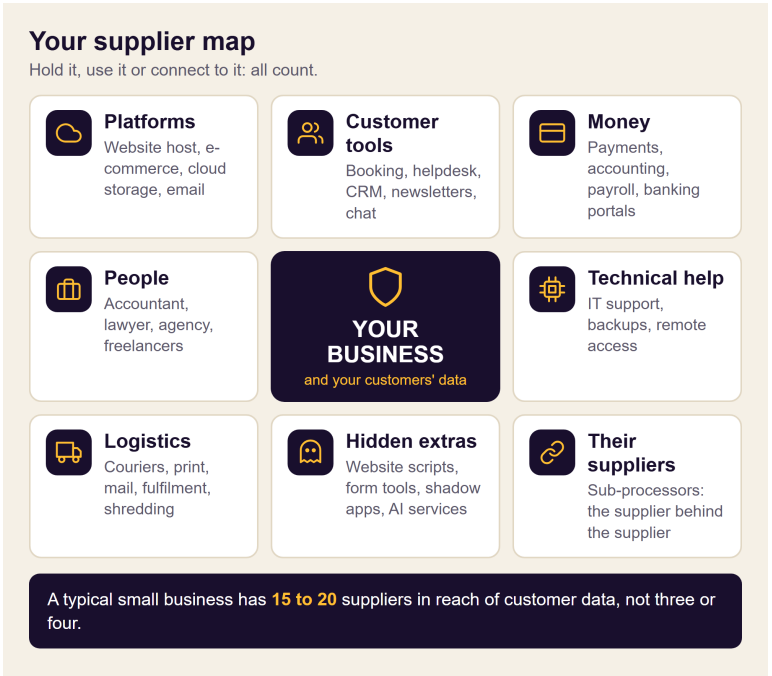
# Who Your Suppliers Really Are




Ask an owner how many suppliers handle customer data and the answer is usually "three or four". Count properly and it is closer to fifteen or twenty. The difficulty is not carelessness. It is that "supplier" covers very different things, and many were never bought through a purchasing process at all.

## The supplier map

Start by listing every organisation that does one of three things: **holds** your data, **uses** your data, or **connects** to your systems. Almost every business has some of each of these categories.




A typical small business supplier map: who holds, uses or connects

- **Platforms you build on.** Website host, e-commerce platform, cloud storage, email and office suite.
- **Customer-facing tools.** Booking, helpdesk, chat widget, live chat, reviews, newsletters, CRM.
- **Money.** Payment processor, accounting software, payroll, expense tools, your bank's portals.
- **People and professionals.** Accountant, bookkeeper, lawyer, marketing agency, freelance developer, virtual assistant.
- **Technical help.** IT support firm, managed service provider, remote-access tools, backup service, security tooling.
- **Physical and logistics.** Couriers, print and mail houses, fulfilment centres, shredding and archive services.
- **Hidden extras.** Analytics and advertising scripts on your website, form tools, scheduling links, survey tools, and the AI services your team may be pasting data into.

## Processors, controllers and everyone in between

Data-protection law uses two words you will see throughout the rest of this book.

A **controller** decides *why* and *how* personal data is used. For your own customers' data, that is you.

A **processor** handles personal data *on your behalf and on your instructions*. A payroll provider, a hosting company or an email-sending platform is usually a processor. It is allowed to do what you tell it with the data, and nothing else.

Some suppliers are neither. A bank, an accountant acting under their own professional rules, or a courier delivering to your customer's address may be a **controller in their own right** for part of what they do. A marketing platform that uses your list to improve its own products may have crossed from processor into something else. The label changes what the contract must say, so it is worth asking early rather than guessing [2].

## The supplier behind the supplier

Your supplier has suppliers. Your email-marketing tool runs on a cloud provider, uses a separate delivery service, and calls a support platform that stores your customers' replies. Law calls these **sub-processors**, and they matter for two reasons: your data may be in more places than you realise, and a failure three steps away can still reach you.

You do not need a perfect map of every layer. You need to know that the layers exist, to ask each important supplier for its list of sub-processors, and to make sure the contract says you will be told before that list changes.



Photograph: the supplier behind the supplier runs in a data hall you will never see

## Fourth parties and "shadow" suppliers

Two kinds of supplier almost never appear on an official list.

- **Shadow suppliers** are tools staff signed up for with a work email and a credit card: a free file-sharing site, a PDF converter, a survey tool, an AI note-taker. Each one is a supplier holding company data, whether or not procurement ever heard of it.
- **Informal suppliers** are the cousin who built the website, the freelancer with admin access to your store, the part-time IT friend who still has the password. They are often the weakest link, because there is no contract and no offboarding.

**Quick win:** ask your team to list, in five minutes, every tool they used last week that contains customer information. Compare it with your official list. The gap is the first thing to fix.

## Why a register comes first

You cannot assess, contract or monitor what you have not listed. The supplier register in Appendix A is deliberately simple: who, what they do, what data they hold, who owns the relationship, and when you last looked. It is the one document that makes every later step possible.

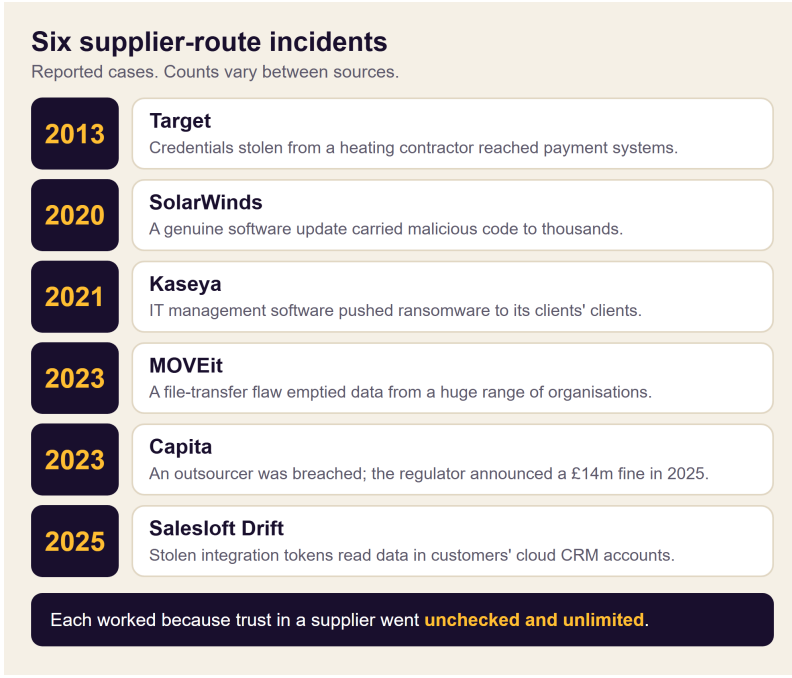
> **The rule.** If a supplier is not on your register, you are not managing the risk. You are hoping.

CHAPTER 3

# How It Has Already Happened




Real incidents teach more than any theory, because they show how ordinary the first step usually is. The cases below are well documented, and each one is told in the shortest honest form. Details and figures vary between sources, and the notes at the back say where to check them [3].




Six well-known supplier-route incidents, 2013 to 2025

## Target, 2013: the heating contractor

An attacker stole network credentials belonging to a refrigeration and heating contractor that worked with the US retailer Target. Those credentials gave access that, through weaknesses in how the retailer's network was divided, led to the systems that handled card payments. Tens

of millions of customers' card details were taken. The lesson that stuck: a supplier with a low-risk job, for example monitoring building systems, can hold a key to the highest-risk part of your business unless access is deliberately limited.

### SolarWinds, 2020: the trusted update

Attackers compromised the build process of a widely used network-management product and slipped malicious code into a genuine software update. Thousands of customers installed it in the normal way. The lesson: even a supplier you assess carefully can be turned into a delivery route, so you need ways to limit and detect what its software and staff can do inside your world.

### Kaseya, 2021: the tool that manages the tools

Criminals exploited the remote-management software that IT service providers use to run their clients' computers, and used it to push ransomware to many small businesses at once. The lesson: the IT firm that "looks after everything" is, by design, powerful. Its tools deserve the closest scrutiny, not the least.

### MOVEit, 2023: the file-transfer product

A flaw in a popular managed file-transfer product was exploited at scale by a criminal group, and data was taken from a very large number of organisations, from banks to schools to public bodies, and from the organisations that used them as suppliers in turn. The lesson: you can be affected by a breach at a supplier of your supplier, and you might learn it from a news story.

### Capita, 2023: the outsourcer

The outsourcing and software group Capita suffered a cyber attack that exposed personal data held on behalf of many clients, including pension schemes and public bodies. The UK Information Commissioner's Office later announced a £14 million fine, reported as October 2025 [3]. The lesson: regulators look closely at the **supplier**, and clients of that supplier were left to work out what had been taken and whom to tell.

### Salesloft Drift, 2025: stolen keys to other people's systems

In 2025 attackers obtained authentication tokens from a chat and sales-automation integration and used them to read data from many customers' connected cloud-CRM accounts. Nothing needed to be broken in the customers' own security, because the tokens were valid. The lesson: every connection you authorise (an "app", a "plug-in", an "integration") is a credential that can be stolen from someone else's house.

### What the cases have in common

| Pattern | What it looked like |
|---|---|
| A supplier's weakness, your harm | The victim was often doing its own job competently. |
| A key, not a crowbar | Stolen logins, valid tokens or genuine updates did the work. |
| Too much access | The supplier could reach more than the job required. |
| Slow, unclear notice | Clients learned late, from the supplier, the press or their own customers. |
| A paper trail missing | Few victims could quickly show what they had agreed, checked or limited. |

None of these needs advanced technology to prevent. They need four dull habits: know who they are, limit what they can reach, agree the rules in writing, and keep watching. The next chapters build each habit in turn.

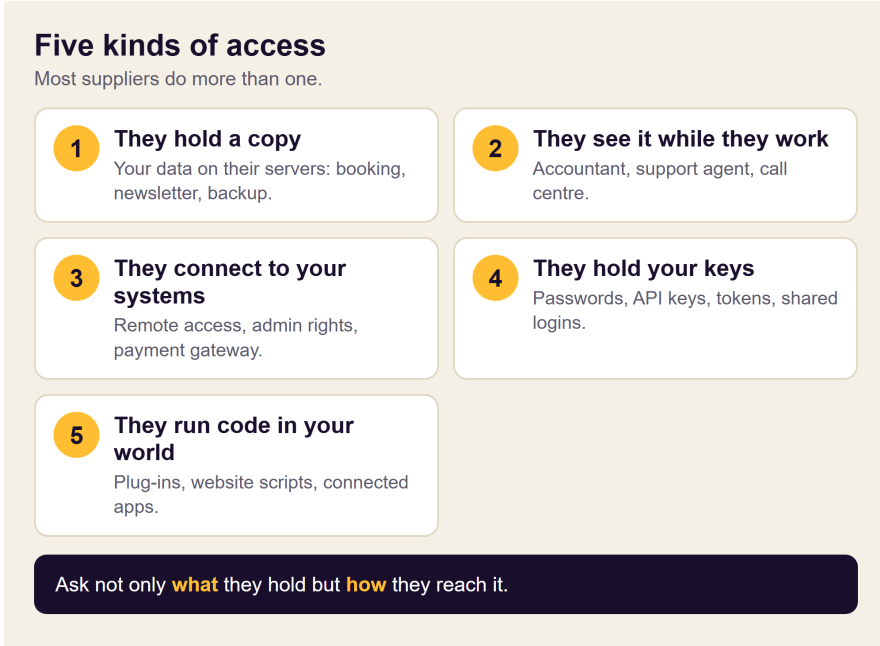
CHAPTER 4

# What Your Suppliers Can Touch




"Does this supplier have my customers' data?" is a good first question but a poor last one. The better question is: **what can this supplier touch, and how?** Two suppliers can hold the same list of names and pose very different risks, depending on how they get to it and what else they can reach.

## Five kinds of access




Five ways a supplier can reach your customers' information

**1. They hold a copy.** Your data lives on their servers: the booking system, the newsletter list, the cloud backup. If they are breached, it goes with them. Risk grows with *how much* they hold and *how long* they keep it.

**2. They see it while they work.** Your accountant, a support agent or an outsourced call centre looks at customer records on your systems or theirs, but may not keep them. Risk lives in *who* can look, and whether it is logged.

**3. They connect to your systems.** An IT firm with remote access, a developer with admin rights on your shop, a payment gateway wired into your checkout. Risk is the size of the door: what can that connection reach beyond the job?

**4. They hold your keys.** Passwords, API keys, access tokens, shared logins to your cloud or social accounts. A stolen key does the same work as a stolen identity.

**5. They run code inside your world.** Plug-ins, scripts on your website, software agents on your laptops, apps connected to your accounts. They act with your authority, so a compromised supplier becomes a compromised you.

Most suppliers do more than one. A marketing agency may hold your list (1), log in to your website (3) and manage your ad accounts (4).

## The access inventory

For every supplier on your register, answer five plain questions. Appendix A has a column for each.

- **What data?** Names and emails? Payment details? Health, children's or financial information? Employee records?
- **How many people?** Ten customers, or ten thousand?
- **How do they reach it?** Copy held, view only, remote connection, key held, code running.
- **Where is it?** Which country? Which sub-suppliers? Transfers outside the EU or UK need their own legal basis [2].
- **For how long?** Is it deleted when no longer needed, or kept for ever because nobody asked?

## Special categories need special care

Some data increases the stakes sharply: health information, biometric data, data about children, financial account details, government identifiers, and anything that reveals religion, political views or sexual orientation. If a supplier touches these, treat it as top priority whatever else is true. A breach of this kind is more likely to harm the individual, and so more likely to trigger the duty to tell them and the regulator [2].

## Data minimisation is the cheapest control

The best protection against a supplier breach is to give the supplier less. Before you connect a tool, ask:

- Does it need the full customer record, or just a name and email?
- Does it need history, or only current customers?
- Can the data be pseudonymised, with a code in place of the identifying fields?
- Does it need admin access, or would read-only do?

What a supplier does not hold cannot be lost by a supplier.



Photograph: an access point most people never look at

## Common over-access traps

- **The shared admin login.** One password for the agency, the freelancer and the intern. No audit trail, no way to remove one person.

- **The "temporary" access that stayed.** The developer who fixed the checkout in 2022 and still has full rights.
- **The full export.** A supplier asks for "a copy of your customer list" to get started, and keeps it.
- **The silent upgrade.** A tool adds a new feature that asks for broader permission, and someone clicks Accept.
- **Production data in testing.** Real customer records copied into a supplier's test or demo environment.

**Quick win:** open the admin area of your three most important accounts (website, email, cloud storage) and look at the list of users and connected apps. Remove everyone and everything you cannot explain.

> **The rule.** For every supplier: the least data, the narrowest access, for the shortest time. Everything else in this book is built on that sentence.

CHAPTER 5

# Tier Your Suppliers



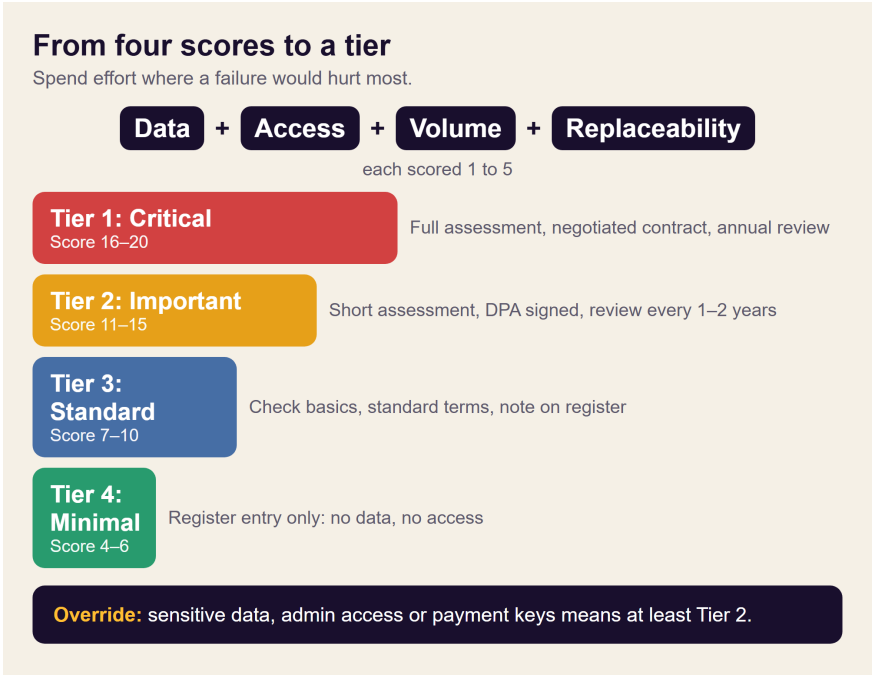

You cannot give every supplier a full investigation, and you should not try. Your pen supplier and your payroll provider do not deserve the same scrutiny. **Tiering** is the simple act of deciding where to spend your limited attention.

## Four questions, scored

For each supplier, score from 1 (low) to 5 (high):

| Factor | What it asks |
|---|---|
| **D: Data** | How sensitive is the data they can touch? |
| **A: Access** | How deeply do they connect to your systems and accounts? |
| **V: Volume** | How many people's information is involved? |
| **R: Replaceability** | How hard and slow would it be to do without them tomorrow? |

Add the four scores. The total runs from 4 to 20.




Turn four scores into a tier and a level of effort

| Total | Tier | What it means |
|---|---|---|
| 16 to 20 | **Tier 1: critical** | Full assessment, written contract with security terms, annual review |
| 11 to 15 | **Tier 2: important** | Short assessment, DPA signed, review every year or two |
| 7 to 10 | **Tier 3: standard** | Check the basics, accept standard terms, note on register |
| 4 to 6 | **Tier 4: minimal** | Register only; no personal data and no access |

**An override rule.** If a supplier has *any* sensitive data, any admin-level access to your systems, or a key to your payments, it is at least Tier 2, whatever the total says.

## A worked example (fictional)

Hartley & Dunn is a small training company with 4,000 customers. Two of its suppliers:

- **Lattice Ledger**, its online accounting tool: invoices include names, addresses and bank details (D = 4), a connection to the bank feed (A = 4), 4,000 customers (V = 3), and moving would take weeks (R = 4). Total 15: **Tier 2**, and the bank access nudges it toward closer attention.
- **PixelPrint**, a company that prints its event badges: names only (D = 2), no system access (A = 1), 200 names at a time (V = 1), easy to replace (R = 1). Total 5: **Tier 4**.

The point is not the number. It is that Hartley & Dunn now spends its careful hour on the accounting tool, not on badge printing.

## Where the tiers meet reality

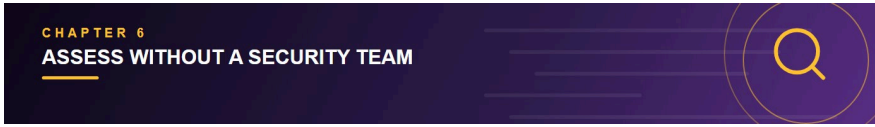
Three practical notes:

- **Re-tier when anything changes.** A supplier that was Tier 4 becomes Tier 2 the day it is given customer data or a login.
- **The free tool is not Tier 4.** Free tools often make their money from data. Tier on what they can touch, not on what you pay.
- **Concentration risk counts.** If one platform runs your website, email, backups and customer list, a single failure takes everything. Note it, and ask what you could do if that platform vanished for a week.

> **The rule.** Spend your attention where a failure would hurt most, not where the sales team is most persuasive.

CHAPTER 6

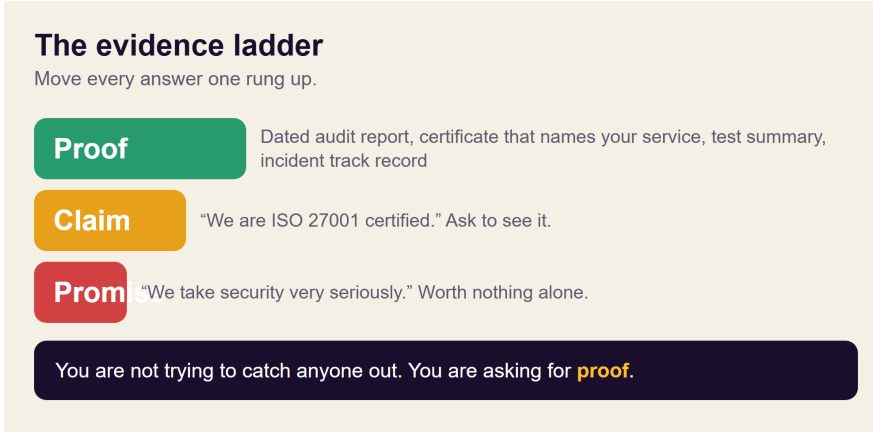
# Vendor Security Assessments Without a Security Team




A vendor security assessment sounds like a corporate ritual involving spreadsheets and consultants. For a small business it can be done in about twenty minutes per supplier, using a handful of sensible questions and a habit of asking for evidence.

## Promises, claims and proof

When a supplier tells you about its security, what you hear sits on one of three rungs.




The evidence ladder: how much weight to give what a supplier says

1. **A promise.** "We take security very seriously." Costs nothing. Worth nothing on its own.
2. **A claim.** "We are ISO 27001 certified." Meaningful if true, so ask for the certificate.

3. **Proof.** A certificate that names the right service and is in date, an independent audit report, a recent penetration-test summary, a public security page with dated detail, or a track record of how it handled a past incident.

You are not trying to catch anyone out. You are simply moving each answer one rung up the ladder.

## The twenty-minute assessment

Work through these eight areas, from the most important to the least. Each has one plain question, and Appendix D expands them into a full questionnaire.

1. **Who controls access?** Do they use multi-factor login for staff and for admin accounts? Is access limited by role?
2. **Is data protected?** Encrypted in transit and at rest? Where is it stored, and by whom?
3. **Can they find and fix problems?** Do they patch promptly, monitor for attacks and keep logs?
4. **Can they recover?** Are backups tested? What happens if they are hit by ransomware?
5. **What do they do if it goes wrong?** Is there a written incident process? How fast will they tell you?
6. **Who else touches your data?** Which sub-processors? Where are they based?
7. **How do they treat staff and access?** Background checks, training, and removal of access when someone leaves.
8. **What independent proof do they have?** Certificates, audits, test reports, a public trust page.



Photograph: the evidence is on paper, not in the sales deck

## Match the effort to the tier

| Tier | Assessment |
|---|---|
| 1 | Full questionnaire, evidence reviewed, a call with the supplier, contract negotiated |
| 2 | Short questionnaire (Appendix D, core questions), certificate or report checked |
| 3 | Read their public security and privacy pages, confirm the DPA, note the date |
| 4 | Register entry only |

## Questions that reveal a lot

Some questions work well because honest suppliers answer them quickly and weak ones squirm.

- "If you had a breach affecting our data tonight, who would call us, and by when?"
- "Which companies do you use to store or process our data?"
- "When did you last restore from a backup, and how long did it take?"
- "Can I see the scope of your certificate? Does it cover this specific service?"
- "What access do your staff have to our data, and how is it logged?"
- "What happens to our data when we leave?"

## Red flags

Any one is a reason to look harder. Several together are a reason to walk away.

- No way to reach a named person about security or privacy.
- Refusal to say where data is stored, or who else handles it.
- No multi-factor login offered, even for administrators.
- A certificate that does not name the service you are buying.
- Vague, evasive or copy-pasted answers to specific questions.
- A history of breaches handled badly, with no public explanation.
- No data processing agreement available, or a refusal to sign one.
- A contract that makes you responsible for the supplier's own failures.
- Pressure to decide quickly, or to skip the questions "just this once".




Twelve warning signs on a supplier assessment

**The rule.** A good supplier welcomes your questions. A supplier that treats basic questions as an insult is telling you something.

CHAPTER 7

# Reading the Evidence




Suppliers will hand you documents: certificates, reports, summaries, trust-centre links. A pile of paper is not proof. This chapter teaches you to read the handful of documents you will actually meet, and to spot the four ways they quietly mislead.

## The documents you will see

**An ISO/IEC 27001 certificate.** Shows that an independent body audited the supplier's information-security management system against a recognised standard. It is a good sign. It is not a guarantee that the supplier is secure, and it says nothing about whether *your* service was in scope.

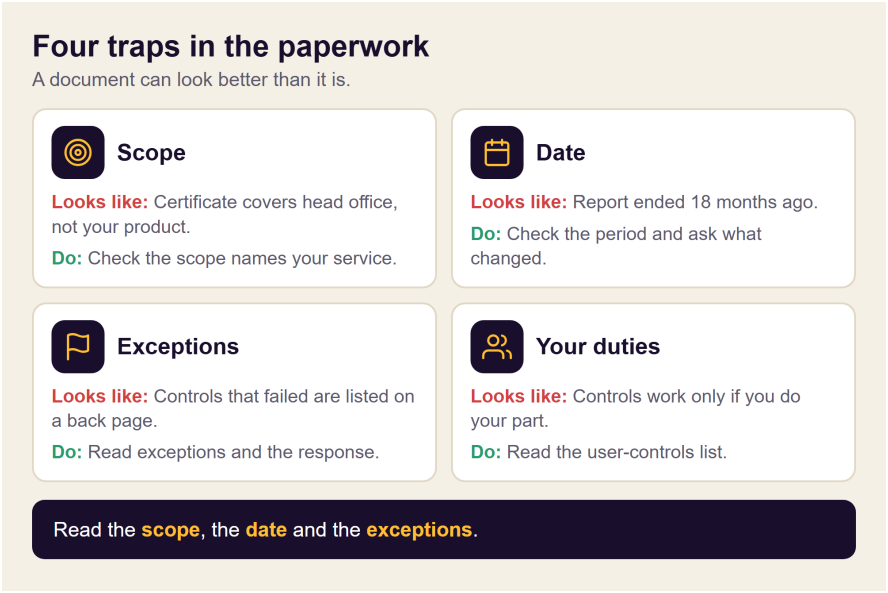
**A SOC 2 report.** Common among US and cloud suppliers. An auditor tests a set of controls and writes an opinion. A "Type I" report looks at design at one date. A "Type II" looks at whether the controls worked over a period, typically six to twelve months, so it is the stronger of the two.

**A penetration-test summary.** A specialist tried to break in and wrote up what they found. Look at the date, who did it, and whether serious findings were fixed.

**A security or "trust" page.** Useful if it is dated and specific. Less useful if it is a list of logos.

**A completed questionnaire.** Only as good as the honesty and the evidence behind it.

## Four traps in the paperwork




Four ways a security document can look better than it is

**Scope.** A certificate covers a defined part of the business. The supplier may be certified for its head office but not for the product you use. *Check the scope statement names your service.*

**Date.** Certificates run for three years with annual checks; reports describe a window. A report that ended eighteen months ago says little about today. *Look at the dates, and ask what has changed since.*

**Exceptions.** A SOC 2 report may be "qualified", or list exceptions where a control failed. These are the most revealing pages and the ones most often skipped. *Read the section on exceptions and the supplier's response.*

**Complementary controls.** Audit reports often list things *you* must do for the controls to work, such as managing your own users sensibly. *Check the list, because those become your responsibility.*

## A simple way to read a report

You do not need to understand every control. Read in this order and stop when you have what you need:

1. The front page: who audited, what was in scope, what period.

2. The auditor's opinion: clean ("unqualified") or with reservations.
3. Any listed exceptions or deviations, and management's response.
4. The list of sub-service organisations: who else is involved.
5. The complementary user-entity controls: what you must do.

Ten minutes on those five items tells you more than the other eighty pages.

## When you cannot get the document

Smaller suppliers often have no certificate. That is not automatically a red flag; many good, small suppliers rely on other evidence. Ask instead for:

- a short written description of their security practices,
- confirmation of multi-factor login, encryption and backups,
- the name of their hosting provider (whose own certificates you can often see),
- a clear incident-notification promise in the contract.

A small supplier that answers openly and specifically deserves more trust than a large one that only forwards a brochure.

## Record what you decided

Write down, in one or two lines, what you saw and what you concluded: "ISO 27001 cert reviewed 3 Nov 2026, covers the platform, valid to 2028, no exceptions noted. Accepted." That note is the evidence that you assessed the supplier at all. It costs a minute and may be worth a great deal later.

> **The rule.** Read the scope, the date and the exceptions. A certificate you have not read is a logo.

CHAPTER 8

# Contractual Responsibilities: What Must Be in Writing




The contract is where your expectations become the supplier's obligations. Without the right terms, you are relying on goodwill. With them, you have rights, deadlines and a basis for a claim.

You do not need to draft contracts yourself. You do need to know what to look for, because most small suppliers send their own standard terms, and the decision is whether to accept them, ask for changes or walk away.

## Start with the law: the data processing agreement

If a supplier processes personal data on your behalf, the GDPR requires a written contract between you and that processor, setting out what the processing is, how long it lasts and what the supplier must do [2]. In practice this is a **data processing agreement** (DPA), either a separate document or an annex to the main contract. Many suppliers publish a standard DPA that you accept online.

The law lists what a DPA must say. In plain terms, the supplier must agree to:

- process personal data **only on your documented instructions**,
- keep the people who handle the data under a **duty of confidentiality**,
- apply appropriate **security measures**,
- use **sub-processors** only with your permission, and pass the same obligations down to them,
- **help you** respond to people exercising their rights,
- **help you** with security, breach notification and impact assessments,
- **delete or return** the data when the service ends,
- give you the **information needed to show compliance** and allow **audits** or inspections.




What a good supplier contract contains, layer by layer

## Beyond the legal minimum: the security schedule

The DPA sets a legal floor. For Tier 1 and Tier 2 suppliers, add a short schedule describing what the supplier actually does. It does not need to be long; it needs to be specific.

- Multi-factor authentication for all staff with access to your data.
- Encryption of your data in transit and at rest.
- Regular backups, tested restoration, and a stated recovery time.
- Prompt patching of known vulnerabilities.
- Logging of access to your data, kept for a stated period.
- Staff screening, training and removal of access at departure.

## The clause that matters most: breach notification

The GDPR requires a processor to notify the controller "without undue delay" after becoming aware of a personal data breach [2]. "Without undue delay" is not a number. Meanwhile, **you** typically have 72 hours from

becoming aware to tell your regulator if the breach is likely to put people at risk. If the supplier takes a week to tell you, much of your window has gone.

So write down a number. A common request in small-business contracts is notice within 24 to 48 hours of the supplier becoming aware, with ongoing updates. Ask for:

- a **maximum time** to notify you (for example 24 hours, 48 at the outside),
- a **named contact** and an out-of-hours route,
- the **minimum content**: what happened, which data, how many people, what has been done,
- **cooperation**: access to logs, staff and findings to help you meet your own duties,
- a promise **not to notify your customers or the press** about your data without agreeing it with you, unless the law forces them to.

A sample clause appears below. It is a starting point for a lawyer to adapt, not legal advice.

```
Breach notification. The Supplier shall notify the Customer without
undue delay, and in any event within 48 hours, after becoming aware
of any personal data breach affecting Customer Data. The notice shall
describe, so far as known: the nature of the breach; the categories
and approximate number of individuals and records; the likely
consequences; and the measures taken or proposed. The Supplier shall
provide further information as it becomes available, shall cooperate
with the Customer's investigation and regulatory notifications, and
shall not communicate with the Customer's customers about the breach
without the Customer's prior agreement unless required by law.
```

## Other terms worth checking

| Term | What to look for |
|---|---|
| **Sub-processors** | A current list, notice of changes, and a right to object |
| **Location** | Where data is stored and accessed; transfer safeguards if outside the EU/UK |
| **Audit and evidence** | Right to review certificates and reports; a route to an audit if needed |
| **Return and deletion** | A timescale, and written confirmation when done |
| **Cooperation on rights requests** | Time limits that fit your own one-month deadline |

| Term | What to look for |
|---|---|
| **Termination and exit** | Ability to export your data in a usable format, and a transition period |
| **Insurance** | Cyber and professional cover held by the supplier, at a stated level |
| **Changes to terms** | No silent changes to security or data use |

## When the supplier will not negotiate

Large platforms rarely change their terms for a small customer. That is normal. Your choices are then to:

1. **Read what they offer.** A good standard DPA already covers the legal minimum. Confirm that it does.
2. **Limit what you give them.** If the terms are thin, reduce the data and the access.
3. **Document your decision.** Note the risk, the mitigation and who accepted it.
4. **Choose differently.** If a terms gap is serious, the price of the cheaper tool may not be worth it.

> **The rule.** If a supplier handles personal data for you and there is no signed DPA, stop and fix that first. It is the single most common gap, and the easiest to close.

CHAPTER 9

# Who Pays? Liability, Insurance and the Limits of Contracts



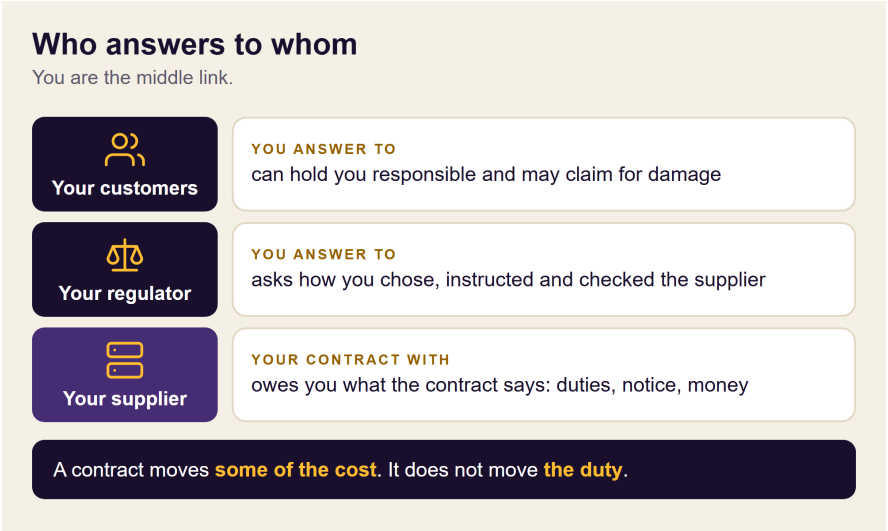

Contracts allocate money as well as duties. When a supplier's failure costs you a fine, a legal bill, customer compensation and months of lost trade, the clause that says who pays becomes the most read page in the file. Unfortunately, it is usually the page that was never read at signing.

## What the contract cannot do

A contract between you and a supplier governs *your relationship with them*. It does not change your relationship with your customers or your regulator.

- Your **customers** can still hold you responsible, and under the GDPR, a person who suffers damage can claim compensation for it [2].
- Your **regulator** can still examine whether *you* chose and instructed the supplier properly.
- A clause that says "the supplier is liable for everything" will not stop either of them from coming to you.

What the contract *can* do is help you **recover your losses from the supplier** afterwards, if the supplier was at fault and the contract lets you.




Who answers to whom: three relationships, three kinds of responsibility

## Liability caps

Almost every standard contract limits how much the supplier will pay. A typical cap equals the fees paid in the previous twelve months. For a €30-a-month tool, that is a few hundred euros. If a breach costs you €80,000, you have a gap.

Questions to ask:

- What is the cap, and is it per claim or in total?
- Are data-protection and confidentiality breaches **inside** the cap, or is there a **higher "super-cap"** for them?
- Are any losses excluded altogether, for example "indirect" losses or lost profit, which may be exactly the losses you suffer?
- Does the cap apply equally to both sides?

Small customers seldom win an unlimited-liability clause. A realistic aim for important suppliers is a higher cap for data breaches, tied to the risk or to the supplier's insurance level, and a clear statement that the cap does not apply to the supplier's own wilful misconduct, where the law does not allow it anyway.

## Indemnities and costs

An **indemnity** is a promise to cover specified costs. For data incidents, the useful version covers the reasonable cost of **notifying people, credit or identity monitoring, forensic investigation, regulator fines where lawful to recover, and legal defence**. Be aware that in many places fines cannot lawfully be passed on to someone else; ask a lawyer before counting on this.



Photograph: contracts allocate money as well as duties

## Insurance: both sides

**Their insurance.** Ask which cyber and professional-indemnity cover your supplier holds, and for roughly what level. It shows how seriously they take the risk and what they can pay.

**Yours.** A cyber policy can pay for investigation, notification, legal help and business interruption. Read it for:

- whether **supplier or "dependent business" failures** are covered or excluded,
- security **conditions** the insurer expects, such as multi-factor login or tested backups,
- a **notification deadline** to the insurer, often very short,
- whether you must use the insurer's **panel of responders**.

Ring your broker before a breach to find out. Finding out afterwards is the common mistake.

## Practical ways to reduce the damage if the clause is weak

- **Hold less.** Delete data you no longer need, and give the supplier less in the first place.
- **Encrypt or pseudonymise** before sending, where practical.
- **Keep your own copy** of data you cannot afford to lose.
- **Diversify.** Avoid one supplier running everything.
- **Review contract renewals.** Renewal is the natural moment to ask for better terms.

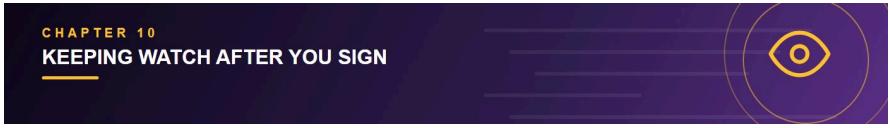
## Joint responsibility and the awkward middle

Sometimes you and a supplier decide *together* how data is used. The law then calls you **joint controllers** and expects a transparent arrangement that sets out who does what [2]. An advertising platform or a shared customer programme can fall here. If you suspect it, ask for advice, because the usual processor contract will not fit.

> **The rule.** A contract can move some of the cost. It cannot move the duty. Draft for recovery, but behave as though the responsibility is yours.

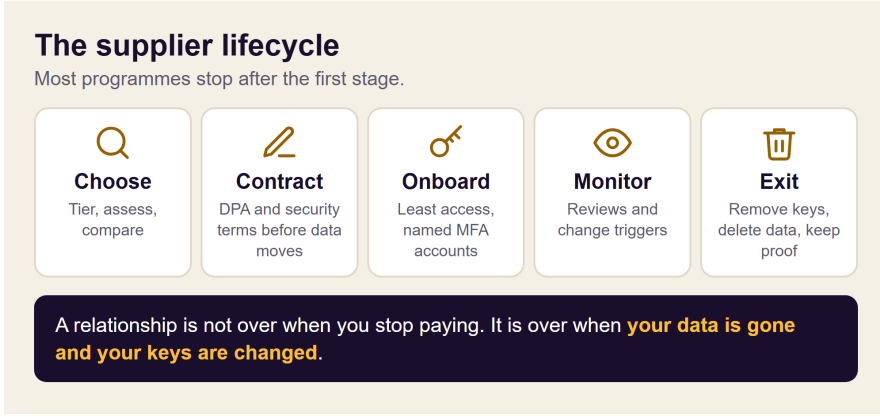
CHAPTER 10

# Keeping Watch After You Sign




Most supplier programmes fail in a boring way: the assessment is done once, filed, and never opened again. Meanwhile the supplier changes. It is bought, hires and fires, adds features, switches hosting, and has its own bad year. The supplier you assessed in 2023 is not the supplier you have in 2026.

## The life of a supplier




The supplier lifecycle: five stages and the question for each

**Choose.** Tier, assess, compare, decide. (Chapters 5 to 7.)

**Contract.** Sign the DPA and security terms before data moves. (Chapter 8.)

**Onboard.** Give the least access, in a named account, with multi-factor login switched on. Record it in the register.

**Monitor.** Review on a schedule and when something changes.

**Exit.** Remove access, recover or delete data, and keep the proof.

## What to review, and how often

| Tier | Review | Content |
|---|---|---|
| 1 | At least every 12 months, plus triggers | Updated evidence, access review, incident history, contract check |
| 2 | Every 12 to 24 months | Certificate in date? Sub-processors changed? Access still right? |
| 3 | At renewal | Quick check of the public security page and terms |
| 4 | Never, unless the data or access changes | Register entry only |

## Triggers that mean "review now"

Do not wait for the calendar if:

- the supplier is **acquired**, merges or changes ownership,
- you hear of a **breach or outage** at the supplier or one of its suppliers,
- the supplier changes **hosting country** or **sub-processors**,
- it launches a **new feature** that uses your data differently, including AI features,
- **key staff** you deal with leave, or support quality drops,
- you start sending it **new types or volumes** of data,
- its **certificate lapses** or a report ends,
- the **terms of service** change.

**Quick win:** set up an alert for each Tier 1 supplier's name plus the word "breach". Five minutes, and you will often hear before they tell you.

## The access review

Once a quarter, for each Tier 1 and Tier 2 supplier, check three things:

- **Who** at the supplier or your own team has an account, and do they all still need it?
- **What** can each account do, and could it do less?
- **What** apps, keys or tokens are connected, and are they still in use?

Remove what you cannot justify. Access that exists "just in case" is the favourite entry point of attackers and the easiest thing to fix.



Photograph: every key that is not accounted for is a door that is not watched

## When a supplier changes its AI practices

Many suppliers now add AI features and may send your data to AI providers as new sub-processors. Read update emails for the words "AI", "assistant", "model" and "improve our services". Check whether your data is used to train models, whether you can opt out, and who the new sub-processor is.

## Exit: the stage everyone forgets

Ending a supplier relationship is a security event. Do not leave it to chance.

- ☐ Export what you need in a usable format.
- ☐ Remove all user accounts, keys, tokens and connected apps.
- ☐ Ask for written confirmation of deletion, including backups, within the contract's stated period.
- ☐ Change any shared passwords the supplier knew.
- ☐ Update the register and keep the correspondence.

> **The rule.** A supplier relationship is not finished when you stop paying. It is finished when your data is gone and your keys are changed.

CHAPTER 11

# When the Breach Comes Through Your Supplier




Sooner or later the call comes. This chapter is the one to read before it does. It assumes the supplier has told you, or you have learned from elsewhere, that your customers' data may have been affected.

## The first hour

### The first 72 hours

The regulator's clock runs from when you become aware.

| 0 to 1 hour<br>Stabilise | 1 to 24 hours<br>Understand | 24 to 72 hours<br>Decide and notify | After 72 hours<br>Repair and learn |
|---|---|---|---|
| • Write down the time you learned<br>• Open the log<br>• Questions to the supplier, in writing<br>• Change keys; cut access | • Which data, how many people<br>• Encrypted? Contained?<br>• Risk: unlikely, likely, high<br>• Tell insurer if required | • Regulator notice if risk is likely<br>• Tell people if risk is high<br>• Phase the facts; promise updates<br>• Record the reasons | • Supplier written report<br>• Review within weeks<br>• Keep, condition or replace<br>• Update register and contract |

Note the **time you first knew**. Everything else is measured from it.

The first 72 hours after a supplier tells you about a breach

**1. Note the time.** Write down exactly when and how you first learned. Under the GDPR, the 72-hour period for notifying the regulator runs from when you become *aware* of the breach [2]. European guidance indicates that, where a processor has the breach, the controller is generally treated as aware once the processor informs it. That makes the supplier's notification timing important, and your own note of the time essential.

**2. Open a log.** Appendix E gives you one. Record every fact, decision, call and email with its time. The log is your best defence later.

**3. Get the facts from the supplier.** Ask, in writing:

- What happened, and when did it start and end?
- Was **our** data affected? Which categories? Roughly how many people?
- Was the data encrypted, and were the keys also exposed?
- Is the breach contained? What has been done?
- Who else has been told? Are the authorities involved?
- What do you need from us?

**4. Contain your side.** Change any passwords, keys and tokens the supplier held. Revoke their access to your systems. Pause the integration if that is safe. Do not delete evidence.

**5. Tell the people who need to know inside the business.** Owner, whoever handles data protection, whoever speaks to customers, and your insurer if the policy requires early notice.

## Decide: is it a notifiable breach?

A **personal data breach** is a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data [2]. Not every breach must be reported. The test is risk to people.

| Likelihood and severity | Duty |
|---|---|
| **Unlikely to result in a risk** to people | Record it internally; no notification needed |
| **Likely to result in a risk** | Notify the supervisory authority within 72 hours of becoming aware |
| **Likely to result in a high risk** | Notify the authority **and** tell the affected people without undue delay |

Think about *what could happen to the people* involved: fraud, identity theft, phishing that quotes real details, discrimination, loss of confidentiality, physical danger, financial loss. Data of children or special-category data raises the risk. Strong encryption, where the keys were not exposed, may lower it.

**If you are unsure, notify.** Late is worse than early; an early notice can be updated, and the law allows information to be provided in phases when it is not all available at once [2].

## Who notifies?

The controller notifies. That is normally **you**, not the supplier. A supplier that tells its own regulator has not discharged your duty, and you should not assume it will tell yours. If your supplier is also a controller for some of the data, each of you may have separate duties. If in doubt, ask your regulator or lawyer.

## What goes in the notice

The authority will usually expect, via an online form:

- the nature of the breach, including the categories and approximate numbers of people and records,
- the contact point for more information,
- the likely consequences,
- the measures taken or proposed, including to reduce harm.

If you do not yet have all the facts, say so, and promise a follow-up. A partial, honest notice made on time beats a perfect one made late.

## Keep the paper trail, even if you do not notify

The GDPR requires you to **document every personal data breach**, with the facts, its effects and the action taken, whether or not it is reported [2]. If you decide not to notify, record why. That decision may be reviewed.

## Check the other clocks

A personal-data breach can start other obligations at the same time.

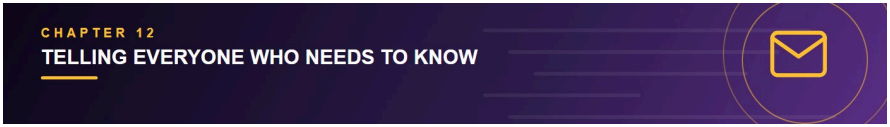
- **Your contracts.** Some customer contracts require you to notify them of security incidents on their own deadlines.
- **Your insurer.** Policies often require notice quickly, and some restrict who may investigate.
- **Sector rules.** Regulated firms, essential services and some digital providers may have separate reporting duties under rules such as NIS2 or DORA [4].
- **Card networks.** If payment card data is involved, your acquirer will have rules.

- **Law enforcement.** For crime such as extortion or fraud, a police report may help.

**The rule.** Write down when you knew, act in the first hour, and decide about notification on the facts, not on how it will look.

CHAPTER 12

# Telling Customers, Regulators and the Supplier




A breach has a technical side and a human side. Customers will forgive an honest, quick, useful message far more readily than a late, vague or defensive one.

## When you must tell people

You must communicate with affected individuals **without undue delay** where the breach is likely to result in a **high risk** to them [2]. You may not need to if the data was properly encrypted, if you have taken steps that make the high risk no longer likely, or if it would involve disproportionate effort (in which case you make a public communication instead). Even when not required, a short, honest note often builds trust.

## What a good customer message contains



Photograph: a message to customers should be calm, plain and complete

- **What happened,** in plain words, and that it was at a supplier you use.

- **What it means for them:** which information, and what risks follow.
- **What you have done,** and what the supplier has done.
- **What they should do:** change passwords, watch for phishing, check statements, and how to freeze or monitor if relevant.
- **How to reach you,** with a real person and a real address.
- **An apology** that does not shift the blame. "The supplier's fault" may be true, and it is not what the customer wants to read.

Avoid jargon, avoid minimising ("limited number of records"), and avoid promises you cannot keep ("your data is now completely safe"). Send it from you, not from the supplier.

## A sample customer message (fictional)

```
Subject: Important: a security incident affecting some of your
information

Dear Maria,

On 4 November we learned that Bookwell Ltd, the company that
runs our online booking system, suffered a security breach. Between
28 October and 2 November an unauthorised person accessed booking
records that include customer names, email addresses and phone
numbers. No payment details or passwords were held in that system.

What this means: you may receive fake messages that use your name or
a recent booking to seem genuine. Please be careful with links and
attachments, and do not share codes or passwords.

What we have done: we have ended the connection, changed our access
keys, reported the incident to the data-protection authority and
asked the supplier for a full report.

If you have questions, please contact Sam on 01234 567890 or
privacy@example.com. We are sorry this has happened.
```

## Talking to your supplier

Stay factual and firm. Put requests in writing and keep copies.

- Ask for a **written incident report** with timeline, cause, data affected, containment and remediation.
- Ask for **logs and evidence** relevant to your data under the cooperation clause.
- Ask for confirmation of **what they told other parties** and when.

- Remind them of the **no unilateral communication** term, if you have one.
- **Reserve your rights.** A short sentence in your emails, such as "we reserve all rights under the contract", costs nothing. Let a lawyer handle disputes about liability.

## Dealing with the regulator

Regulators are not looking for perfection. They look for **reasonable steps, honesty and learning**. Expect to be asked:

- How did you choose and assess this supplier?
- Was there a DPA, and what did it say about breach notice?
- What data did you share, and was it necessary?
- When did you learn, when did you notify, and what did you do between?
- What will you change?

Every page of this book is a way of being able to answer those questions with documents rather than memories.

## After the storm: the review

Within a few weeks, hold a short review and write down what you learned.

- What worked and what did not?
- Did the supplier meet its notification promise?
- Is the supplier still acceptable, with conditions, or to be replaced?
- Which contract terms, access rights or data flows will change?
- Do other suppliers share the same weakness?

Then update the register, the policy and the plan. A breach handled well and learned from can leave a business safer than before.

> **The rule.** Be quick, be honest, be useful. Customers remember how you treated them far longer than they remember which supplier failed.

CHAPTER 13

# Your 30-Day Plan




Everything so far is useful only if it becomes habit. This plan gets a small business from "hoping" to "defensible" in four weeks, at a few hours a week.




Four weeks to a defensible supplier position

## Week 1: See

- ☐ Ask each team member to list every tool and supplier they use that touches customer data (five minutes each).
- ☐ Build the register (Appendix A) from the lists, your bank statements and your card statements.
- ☐ Record, for each supplier, what data it holds and how it connects.
- ☐ Name one person responsible for suppliers and privacy.

**Output:** a register you trust, and an owner.

## Week 2: Rank

- ☐ Score each supplier on Data, Access, Volume and Replaceability (Chapter 5).
- ☐ Assign Tiers 1 to 4, applying the override rule.
- ☐ Identify your top five suppliers by risk.
- ☐ Check which of those have a signed DPA. Request any that are missing.

**Output:** a tiered register and a list of contract gaps.

## Week 3: Check and fix

- ☐ Run the twenty-minute assessment on your top five (Appendix B and D).
- ☐ Read the scope, date and exceptions on any certificate or report.
- ☐ Review the user lists and connected apps on your critical accounts. Remove what you cannot explain.
- ☐ Switch on multi-factor login everywhere it is offered.
- ☐ Ask each Tier 1 supplier for its breach-notification time and named contact.

**Output:** assessments on file, tighter access, and known gaps.

## Week 4: Write and rehearse

- ☐ Adopt the one-page supplier policy (Appendix F).
- ☐ Add the breach-notification clause to renewals and new contracts (Appendix C).
- ☐ Prepare the response log and the customer message template (Appendix E and Chapter 12).
- ☐ Run a 30-minute tabletop exercise: "Our booking tool just told us it was breached. What do we do?"
- ☐ Put the first quarterly review in the diary (Appendix H).

**Output:** a policy, a plan you have practised, and a review date.

## The evidence file

By day 30 you should hold one folder containing:

- the register, with dates,
- your assessments of the top suppliers,
- signed DPAs and key contract pages,
- the policy and the response plan,
- notes from the tabletop exercise,
- the first review log.

That folder is what turns "we took reasonable care" from a hope into a statement you can prove.

> **The rule.** Do a little every week. A modest programme that runs beats an excellent one that never starts.

CHAPTER 14

# Five Case Files




These are fictional stories built from patterns seen in real incidents. They show how the ideas in this book play out when they meet real life. Names and numbers are invented.

## Case 1: The booking tool

**Hartley & Dunn**, a training company with 4,000 customers, used a low-cost booking platform, **Bookwell Ltd**. It held names, emails and phone numbers. There was no signed DPA, only click-through terms. In June the supplier discovered a breach and emailed an "update" to its customers three weeks later.

*What would have helped:* a signed DPA with a 48-hour notice clause (Chapter 8); a Tier 2 rating that triggered an annual review (Chapter 5); a news alert on the supplier's name (Chapter 10). *What they did:* notified the regulator within 72 hours of learning, told customers about phishing risk and moved to a supplier with a stronger contract.

## Case 2: The freelance developer

**Lumen Candles**, a small online shop, had a freelance developer with full admin on its store since 2021. The developer's laptop was infected; the attacker used the stored session to export the customer list.

*What would have helped:* named accounts with limited roles, not a shared login (Chapter 4); an access review each quarter (Chapter 10); removal of access when the project ended. *Lesson:* informal suppliers are suppliers.

### Case 3: The IT support firm

**Pritchard & Co**, an accountancy, relied on a local IT firm that managed all its computers using a remote-management tool. The IT firm's tool was compromised and ransomware spread to its clients, including Pritchard.

*What would have helped:* asking the IT firm about its own security and MFA (Chapter 6); insisting on separate admin accounts and logs; tested offline backups (Chapter 8's security schedule); notification terms. *Lesson:* the supplier with the most power deserves the most scrutiny.

### Case 4: The silent sub-processor

**Greenfield Clinics** used a patient-reminder service. Without notice, the service added a new US-based messaging sub-processor. A breach there exposed appointment messages.

*What would have helped:* a sub-processor clause requiring notice and a right to object (Chapter 8); transfer safeguards; minimising what the reminder contained (Chapter 4). *Lesson:* your supplier's supplier is also your supplier. Special-category data raised the stakes.

### Case 5: The certificate that did not apply

**Bright Path Consulting** chose a client-portal vendor because its website showed an ISO 27001 badge. After a breach, Bright Path discovered the certificate covered only the vendor's head office, not the portal product.

*What would have helped:* reading the scope and date (Chapter 7) and recording the check. *Lesson:* a badge is not an assessment.

### Common threads

Across the five cases the same four moves would have mattered: **know** who they are, **limit** what they touch, **agree** it in writing, **watch** it over time. None needed a security department.

# Conclusion: Close the Back Door




A supplier breach feels like an ambush. In truth it is among the most foreseeable events a small business faces. You know the supplier exists. You know what you gave it. You know it will, at some point, have a bad day.

What you control is what that bad day does to you.

Because you listed your suppliers, you will know within minutes whether the data is yours. Because you tiered them, you will know which phone call matters first. Because you limited access, the harm will be smaller. Because you signed a clear contract, the notice will arrive in time to act on it. Because you wrote the plan, the first hour will be calm instead of chaotic. And because you kept the records, you will be able to tell your customers and your regulator, truthfully, that you took care.

You cannot make a supplier perfect. You can make yourself prepared.

Start with the register. Open Appendix A, and write down the first five names. It will take ten minutes, and it is the first step in closing a door you have probably been leaving open for years.

APPENDIX A

# Supplier Register

One row per supplier that holds, uses or connects to your data or systems. Keep it current and review it every quarter.

| Supplier and service | What it does for us | Data it holds or sees | How it reaches it | Tier | Owner | DPA signed | Last reviewed |
|---|---|---|---|---|---|---|---|
| | | | | | | | |
| | | | | | | | |
| | | | | | | | |
| | | | | | | | |
| | | | | | | | |
| | | | | | | | |
| | | | | | | | |
| | | | | | | | |
| | | | | | | | |
| | | | | | | | |

**How it reaches it** means one or more of: holds a copy, sees while working, connects to our systems, holds our keys, runs code in our world.

**Tier** is from Chapter 5: 1 critical, 2 important, 3 standard, 4 minimal.

APPENDIX B

# Supplier Assessment Form

Complete one for every Tier 1 and Tier 2 supplier before data moves, and again at each review.

**Supplier and service:** _____ **Date:** _____

**Assessed by:** _____ **Supplier contact:** _____

**Job it does for us (one sentence):**

_____

**Tier scores (1 to 5):** Data _____ Access _____ Volume _____ Replaceability _____ **Total** _____ **Tier** _____

| # | Area | Evidence seen | Rung (promise, claim, proof) | Pass? |
|---|---|---|---|---|
| 1 | Access control and multi-factor login | | | |
| 2 | Encryption in transit and at rest | | | |
| 3 | Patching, monitoring and logging | | | |
| 4 | Backups and recovery tested | | | |
| 5 | Incident process and notification time | | | |
| 6 | Sub-processors and data location | | | |
| 7 | Staff screening, training and leaver process | | | |
| 8 | Independent proof (certificate, report, test) | | | |

**Certificate or report scope names our service?** ☐ Yes ☐ No ☐ Not applicable

**Date range of the evidence:** _____ **Exceptions noted:** _____

**Red flags seen (Chapter 6):**

_____

**Contract position:** ☐ DPA signed ☐ Breach notice time agreed ☐ Sub-processor notice ☐ Exit terms

**Decision:** ☐ Approve ☐ Approve with conditions ☐ Reduce data or access ☐ Reject

**Conditions and actions:**

---

**Next review:** _____ **Signed:** _____

APPENDIX C

# Contract Clause Checklist

Use when you read a supplier's terms or DPA. Tick what is present; list what is missing and decide whether to ask, limit or walk away.

**Data processing (the legal floor)**

- ☐ Subject, duration, nature and purpose of the processing are stated.
- ☐ The supplier processes only on our documented instructions.
- ☐ Staff with access are bound by confidentiality.
- ☐ Appropriate security measures are required.
- ☐ Sub-processors only with our permission, with the same duties passed down.
- ☐ Help with individuals' rights requests, within our own deadline.
- ☐ Help with breach notification, security and impact assessments.
- ☐ Deletion or return of data at the end, with written confirmation.
- ☐ Information to show compliance, and audits or inspections.

**Breach and incident**

- ☐ Maximum notification time stated in hours (for example 24 or 48).
- ☐ Named contact and out-of-hours route.
- ☐ Minimum content of the notice.
- ☐ Cooperation: logs, staff, written report.
- ☐ No communication with our customers or the press without agreement, unless the law requires.

**Security and assurance**

- ☐ Security schedule (multi-factor login, encryption, backups, patching, logging).
- ☐ Right to see current certificates or reports.
- ☐ Notice of material changes to security or hosting.

**Location and sub-suppliers**

- ☐ Where data is stored and accessed is stated.

- ☐ Transfer safeguards for data leaving the EU or UK.
- ☐ Current sub-processor list, notice of changes, right to object.

**Money and exit**

- ☐ Liability cap and whether data breaches have a higher cap.
- ☐ No exclusion of the losses we are most likely to suffer.
- ☐ Supplier insurance stated.
- ☐ Data export in a usable format and a transition period on exit.
- ☐ No silent changes to terms.

**Missing items to raise:**

---

APPENDIX D

# Supplier Security Questionnaire

Send to Tier 1 and Tier 2 suppliers. Ask for evidence where a question allows it, and note the rung of each answer: promise, claim or proof.

**Access and identity**

1. Is multi-factor login required for all staff and administrators? _____
2. How is access to customer data limited and reviewed? _____
3. How quickly is access removed when someone leaves? _____

**Data protection**

4. Is our data encrypted in transit and at rest? Who holds the keys? _____
5. In which countries is our data stored and accessed? _____
6. Which sub-processors handle our data? Please attach the list. _____
7. How long do you keep our data, and how do you delete it? _____

**Resilience**

8. How often are backups taken and when were they last restored? _____
9. What is your recovery time target after a serious outage? _____
10. Have you suffered a security incident in the last three years? What changed? _____

**Detection and response**

11. Do you log access to our data, and for how long? _____
12. Do you have a written incident-response plan, tested in the last year? _____
13. Within how many hours will you tell us of a breach affecting our data? _____
14. Who is our named security or privacy contact? _____

**Governance and proof**

15. Do you hold ISO 27001, SOC 2 or similar? Does the scope cover our service? Dates? _____
16. When was your last independent penetration test, and were serious findings fixed? _____
17. How are staff screened and trained on data protection and security? _____
18. Do you use our data to train AI models or improve other products? _____

**Contract and exit**

19. Will you sign a data processing agreement with the clauses in our checklist? _____
20. Can we export our data in a usable format, and will you confirm deletion in writing? _____

APPENDIX E

# Supplier Breach Response Log

Start this the moment you learn of a possible supplier breach. Record times honestly, even when they are uncomfortable.

**Supplier:** _____ **Incident reference:** _____

**First became aware (date and time):** _____ **How:** _____

**Logged by:** _____

| Time | Action, decision or information | By whom |
|---|---|---|
| | | |
| | | |
| | | |
| | | |
| | | |
| | | |
| | | |
| | | |

**First hour**

- ☐ Time of awareness recorded.
- ☐ Questions sent to the supplier in writing (what, when, whose data, contained, who told).
- ☐ Keys, passwords, tokens and connections held by the supplier changed or revoked.
- ☐ Owner, privacy lead, communications lead and insurer informed as needed.
- ☐ Evidence preserved; nothing deleted.

**Within 72 hours**

- ☐ Risk to individuals assessed: ☐ unlikely ☐ likely ☐ high.

- ☐ Decision on notifying the regulator recorded, with reasons.
- ☐ Regulator notified (date and time): _____
- ☐ Affected individuals told if high risk (date): _____
- ☐ Contract duties checked and customers or partners notified as required.
- ☐ Card network, sector regulator or police informed if relevant.

**Afterwards**

- ☐ Written incident report received from the supplier.
- ☐ Review meeting held and lessons recorded.
- ☐ Supplier decision: ☐ keep ☐ keep with conditions ☐ replace.
- ☐ Register, policy and contracts updated.

APPENDIX F

# One-Page Supplier Policy Template

Adapt it to your business and ask a lawyer to review it. Put your name on it, date it and share it with everyone who buys software or hires help.

**Purpose.** To make sure every supplier that touches our customers' or colleagues' information is chosen, contracted, monitored and ended in a way that protects people and shows we took care.

**Scope.** Every organisation or person that holds, uses or connects to our data or systems, including free tools, freelancers and agencies.

**Owner.** _____ is responsible for this policy and the supplier register.

**1. Register.** No supplier handles personal data until it is on the register (Appendix A).

**2. Tiering.** Each supplier is tiered by data, access, volume and replaceability. Any supplier with sensitive data, admin access or payment keys is at least Tier 2.

**3. Assessment.** Tier 1 and Tier 2 suppliers are assessed before use, with evidence, and reassessed at the intervals in Chapter 10.

**4. Contract.** No personal data moves to a supplier without a signed data processing agreement. Tier 1 and Tier 2 contracts state a breach-notification time, sub-processor notice, return and deletion, and security measures.

**5. Access.** Suppliers receive the least data and the narrowest access for the shortest time. Each person has a named account with multi-factor login. Shared admin logins are not allowed.

**6. Monitoring.** Access is reviewed quarterly. A change of ownership, hosting, sub-processors or data use triggers a review.

**7. Incidents.** Anyone who learns of a possible supplier breach tells _____ immediately. The response log (Appendix E) is opened, the time of awareness is recorded, and the 72-hour decision is made.

**8. Exit.** When a supplier ends, access and keys are removed, data is returned or deleted, and written confirmation is kept.

**9. Review.** This policy is reviewed at least once a year.

**Approved by:** _____ **Date:** _____ **Next review:** _____

APPENDIX G

# Notification Worksheet

Use to decide and to record notification to the regulator and to individuals. Complete it in the log as facts emerge; incomplete answers are allowed, but say so.

**1. What happened** (as known):

_____

**2. When it started and ended:** _____ **When we became aware:** _____

**3. Whose breach:** ☐ Our systems ☐ Supplier systems ☐ Sub-supplier ☐ Unknown

**4. Data affected**

| Category | Included? | Approximate people | Sensitive? |
|---|---|---|---|
| Names and contact details | | | |
| Account or login details | | | |
| Payment or bank details | | | |
| Health or special-category data | | | |
| Children's data | | | |
| Identity documents | | | |
| Other | | | |

**5. Was the data protected** (encrypted, keys not exposed)? _____

**6. Possible harm to people** (fraud, phishing, identity theft, distress, discrimination, loss of confidentiality):

_____

**7. Risk rating:** ☐ Unlikely to result in a risk ☐ Likely risk ☐ High risk

**8. Regulator**

| Item | Detail |
|---|---|
| Authority | |
| Notified on | |
| Reference | |
| Follow-up promised by | |

**9. Individuals told:** ☐ Not required, reason: _____ ☐ Yes, on _____ by _____

**10. Measures taken or planned:**

_____

**11. Decision made by:** _____ **Date and time:** _____

APPENDIX H

# Quarterly Review Log

Complete once a quarter. A dated record shows the programme is real.

| Date | Reviewer | New suppliers added | Suppliers ended | Access removed | Changes noticed | Actions |
|---|---|---|---|---|---|---|
| | | | | | | |
| | | | | | | |
| | | | | | | |
| | | | | | | |

**Questions for every review**

- ☐ Is every supplier on the register, and is every tier still right?
- ☐ Is a signed DPA on file for each supplier processing personal data?
- ☐ Are certificates and reports still in date?
- ☐ Have any suppliers changed owner, hosting country or sub-processors?
- ☐ Are accounts, keys and connected apps still needed?
- ☐ Have we heard of any breach, outage or fine involving a supplier?
- ☐ Has data been deleted at every ended contract, with proof?
- ☐ Is the response log current and the contact list correct?

# Glossary

**Audit report (SOC 2).** An independent auditor's report on a supplier's controls. Type II covers a period of time and is stronger than Type I, which covers one date.

**Controller.** The organisation that decides why and how personal data is used.

**Data processing agreement (DPA).** The contract that sets the rules under which a processor handles personal data for a controller.

**Fourth party.** A supplier of your supplier.

**ISO/IEC 27001.** An international standard for managing information security, which a body can certify a company against.

**Joint controllers.** Two or more organisations that decide together how personal data is used.

**Least privilege.** Giving a person or tool only the access needed for its job.

**Multi-factor authentication (MFA).** Signing in with more than a password, for example a code from your phone.

**Personal data breach.** A security failure that leads to accidental or unlawful destruction, loss, alteration, disclosure of or access to personal data.

**Processor.** An organisation that handles personal data on behalf of a controller and on its instructions.

**Residual risk.** The risk that remains after controls are applied.

**Sub-processor.** A supplier used by a processor to handle personal data.

**Supervisory authority.** The national regulator for data protection, for example the ICO in the United Kingdom.

**Supply chain attack.** An attack that reaches you through software or services you trust and use.

**Tier.** A level of supplier criticality that sets how much effort you spend assessing and monitoring it.

**Third party.** Any organisation outside your own that you rely on or share data with.

## A Note on GDPRGard.eu

This book sits alongside **GDPRGard**, a growing set of free tools, guides and articles that help small businesses handle data protection with confidence, including a breach-response guide, a cookie and tracker check, and plain-English explainers on how modern tools meet the GDPR. Visit **gdprgard.eu** for updates on the rules and incidents discussed here.

## About the Author

**Zirlandia Milkovic** writes practical, plain-English guides on data protection, AI and building a business with confidence. She believes privacy is not a barrier to ambition but a foundation of trust, and that business owners should not need a legal degree, or a security degree, to understand the risks that come with the tools and suppliers they use every day.

She is the author of a series of business guides, including *GDPR Made Simple for Women Founders*, and her work focuses on turning complex European rules and fast-moving technology into simple steps, checklists and templates that busy people can actually use. She is also behind **GDPRGard**, a growing collection of free GDPR tools, guides and articles for small businesses, available at gdprgard.eu.

If this guide helped you, an honest review where you bought it helps other readers find it.

# Notes and Sources

Research cut-off: 9 November 2026. Several items below were consulted in earlier research for this series (read, via search summaries and secondary reporting); the others rest on the author's working knowledge of well-known public records. Counts, dates and sums in incident reports vary between sources and should be re-checked against the primary source before you rely on them.

1. Verizon, *Data Breach Investigations Report* 2025, on third-party involvement in breaches (reported at about 30 per cent, roughly double the previous year) (read, via search summaries). Percentages depend on the report's definitions.
2. Regulation (EU) 2016/679 (GDPR), eur-lex.europa.eu: Article 4 (definitions, including controller, processor and personal data breach); Article 5(2) (accountability); Article 26 (joint controllers); Article 28 (processors, including 28(3) contract content); Article 30; Article 32 (security of processing); Articles 33 and 34 (breach notification, including 33(2) processor notice, 33(4) phased information and 33(5) documentation); Articles 44 to 46 (transfers); Article 82 (right to compensation). The UK GDPR and Data Protection Act 2018 are equivalent in these respects, with the Information Commissioner's Office as regulator. European Data Protection Board, *Guidelines 9/2022 on personal data breach notification*, on when a controller is "aware" (working knowledge; check the current text).
3. Incident summaries, from public reporting and regulator or company statements: Target (2013, via a heating and refrigeration contractor's credentials); SolarWinds Orion update compromise (2020); Kaseya VSA ransomware (July 2021); MOVEit Transfer vulnerability and mass data theft (2023); Capita cyber attack (2023) and the ICO's announced £14 million penalty (October 2025) (read, via search summaries); Salesloft Drift OAuth token theft affecting connected Salesforce accounts (August 2025) (read, via search summaries). Numbers of affected organisations and individuals differ across sources.
4. Directive (EU) 2022/2555 (NIS2), Article 21(2)(d) on supply-chain security; Regulation (EU) 2022/2554 (DORA) on ICT third-party risk for financial entities; both at eur-lex.europa.eu. Check whether either applies to your sector.
5. ISO/IEC 27001 and the AICPA SOC 2 framework: descriptions of certificate scope and Type I/Type II reports are general explanations from the author's working knowledge.
6. The sample clauses and customer message in this book are illustrations only. They are not legal drafting and must be adapted by a qualified lawyer for your circumstances.